

FINAL GOAL PRODUCT

AI Security + Business CRM Platform

Complete Product Vision • Company Model • Admin • Employee • Security • UI/UX • Communications • CCTV • AI • Credentials • Provisioning • Certification

SECURITY NOTE: This is the final-target product specification. It combines the project's established architectural decisions with the native-authentication direction. It describes the intended product, not a claim that every capability is currently implemented or production-certified. Implementation status must continue to be recorded separately using PASS / FAIL / BLOCKED / DEFERRED / CODE VERIFIED ONLY / UNVALIDATED.

1. Executive Product Definition

The final product is a secure, tenant-isolated, business CRM and security/operations platform. It combines customer relationship management, revenue operations, internal communication, internal browser calling, workforce management, CCTV/security operations, AI assistance, reporting, notifications/workflows, and enterprise security.

The permanent commercial/deployment direction is not a shared generic SaaS database where customers trust a platform-wide security boundary. The intended customer model is one codebase with a separately provisioned and isolated deployment/environment/infrastructure/credential set per company.

ONE CODEBASE

↓

Company A deployment / environment / infrastructure / credentials

Company B deployment / environment / infrastructure / credentials

Company C deployment / environment / infrastructure / credentials

...

Each company's CRM users authenticate only inside that company's deployment.

Each company's data, secrets, providers and operational state remain isolated.

2. The Three Product Perspectives

The final product must be understandable from three separate perspectives. These perspectives must not be mixed because each has different permissions, responsibilities and security boundaries.

Perspective	What it represents	Primary responsibility	What it must never do
Company / Deployment	The customer's isolated CRM instance and infrastructure	Own its users, data, providers, credentials, policies and operations	Share credentials/data/infrastructure state with another company
Admin	Authorized company operator	Manage company CRM, employees, roles, workflows, approvals, security settings and permitted integrations	See employee passwords/MFA secrets or cross-tenant data
Employee	Normal workforce user	Perform role-authorized CRM, communication, workforce and business tasks	Escalate privileges, change tenant, access unauthorized records or administer protected settings

3. Company-to-Company Operating Model

Company A and Company B are separate customer environments. The product must be designed so that the existence of Company B does not become a data, credential, session, provider or authorization dependency for Company A.

Boundary	Company A	Company B	Required invariant
Authentication	A's own user accounts, passwords, sessions, MFA	B's own user accounts, passwords, sessions, MFA	No shared user credentials
Database	A's isolated database/infrastructure	B's isolated database/infrastructure	No cross-company DB access
CRM data	A customers/leads/deals/etc.	B customers/leads/deals/etc.	No cross-company reads/writes
Provider credentials	A's provider secrets	B's provider secrets	No credential reuse
Redis/cache	A's isolated cache	B's isolated cache	No shared security/session state
Storage	A's storage namespace/resources	B's storage namespace/resources	No cross-company object access
Realtime	A's channels/session state	B's channels/session state	No cross-company signaling
CCTV	A cameras/recordings	B cameras/recordings	No cross-company media
AI	A's authorized AI context/tools	B's authorized AI context/tools	No cross-company prompt/tool context
Audit	A's security/business audit	B's security/business audit	No cross-company audit visibility

SECURITY NOTE: The product must never rely on an email domain, employee number, URL path, frontend selector, or client-supplied tenantId as the actual tenant boundary. Tenant identity must come from the authenticated CRM identity and/or deployment context, with database RLS/FORCE RLS providing a backstop where the architecture uses shared PostgreSQL tenancy.

4. Authentication — Final Direction

The final product is moving toward CRM-native authentication. Clerk is being removed from the target architecture. The CRM itself owns authentication while the existing CRM authorization system remains authoritative.

Authentication:

Browser → CRM authentication → secure session → CRM User

Authorization:

CRM User → tenantId → UserRole → Role → RolePermission
→ server authorization → PostgreSQL RLS/FORCE RLS

- Each company manages its own users and authentication lifecycle.
- Admin and Employee are both CRM identities.
- A password never determines Admin versus Employee; server-side role/permission data does.
- Passwords are stored only as secure password hashes.
- Sessions are opaque, high-entropy, server-controlled and revocable.
- Sessions use Secure + HttpOnly cookies with deliberate SameSite behavior.
- Session fixation is prevented through post-login session rotation.
- Logout revokes the server-side session.
- Disabled users cannot continue using stale sessions.
- Password reset and email verification use hashed, expiring, single-use tokens.
- MFA is supported through protected factors and secure recovery.
- CSRF protection is explicit for cookie-authenticated state changes.
- Login/reset/MFA/invitation abuse is rate-limited.
- Authentication events are audited without logging secrets.

SOURCE / DESIGN BOUNDARY: The separate 'New Authentication System' specification is the governing design for the native-authentication replacement.

5. Company Admin — Complete Product Role

The Company Admin is the primary company operator. The Admin's capabilities are still subject to server-side permissions and cannot be inferred from the frontend.

- View the company dashboard and business health.
- Manage Customers and Contacts.

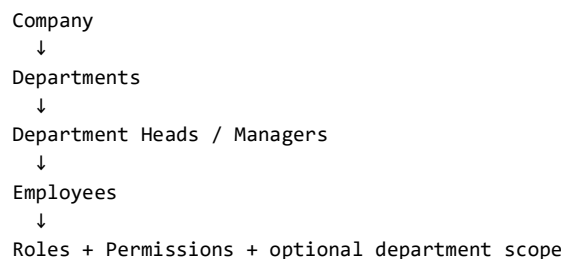
- Manage Leads and pipeline.
- Manage Deals and commercial lifecycle.
- Manage Products and Price Books.
- Create and manage Quotes and Quote Versions.
- Manage approval workflows where authorized.
- Create and manage Tasks/Activities and timelines.
- Manage tickets/incidents where enabled.
- Manage employees through invitation/provisioning lifecycle.
- Assign department/designation/role according to the company's RBAC model.
- Disable/reactivate employees according to authorization.
- Use internal communication features permitted to Admin.
- Use internal browser calling where enabled.
- View authorized reports and dashboards.
- Manage notification/workflow settings where permitted.
- Manage company/security settings exposed to the role.
- View security/audit information that the Admin is authorized to see.
- Configure approved provider integrations for the company's deployment.
- Perform logout/global session management for their own account; administrative session controls must never expose employee credentials.

6. Employee — Complete Product Role

Employees use the same CRM product but receive only the pages, records, actions and tools permitted by their role, department scope and company tenant.

- Authenticate using their own account.
- See the Employee dashboard appropriate to their role.
- View/create/update CRM records only when permitted.
- Work on assigned customers, leads, deals, tasks and tickets as permitted.
- Use internal chat/mail/calling where authorized.
- View only permitted employee/company information.
- Receive and act on authorized notifications/workflows.
- Use AI features only within the same authorization boundary as direct CRM actions.
- Cannot choose their tenant.
- Cannot change their own role or permissions through request payloads.
- Cannot call Admin-only APIs merely because a UI button is hidden.
- Cannot access another employee's protected records without authorization.
- Cannot access another company's records.

7. Workforce / Company Structure



The workforce model connects business organization to authorization without turning business fields into authentication credentials.

- Employee ID is a business identifier, not proof of authentication.

- Department membership can influence scope where the implemented authorization model supports it.
- Role/permission decisions remain server-side.
- Employee lifecycle is auditable.
- Invite → activate → operate → disable/reactivate must be deterministic.
- Deactivation must invalidate effective access, including stale sessions.

8. Core CRM — Customers and Contacts

Customers are the central business entities. Contacts represent people associated with customers and support relationship-level work.

- Customer list with search/filter/pagination where implemented.
- Customer creation/editing and authorized lifecycle controls.
- Contact creation and customer association.
- Contact search/filter and authorized update/archive behavior.
- Customer detail with related contacts, leads, deals, tasks and activity timeline.
- Tenant and permission filtering on every operation.
- Duplicate-handling rules should be explicit and auditable.
- Sensitive contact/customer data should not leak through search, autocomplete, exports or error messages.

9. Leads and Pipeline

- Lead creation and lifecycle management.
- Lead qualification/status changes.
- Lead-to-Deal conversion where supported.
- Assignment and ownership according to RBAC.
- Activity timeline and related customer/contact context.
- Search and filters remain tenant/permission scoped.
- Conversion must not create cross-tenant relationships.
- Lifecycle operations must be transactional where multiple records change together.

10. Deals

- Deal creation/editing.
- Customer/lead association.
- Deal stage/pipeline state.
- Value and commercial information.
- Assignment/ownership.
- Activity/timeline relationships.
- Authorized lifecycle transitions.
- Tenant-scoped reporting.
- No trust in client-supplied ownership or tenant identifiers.

11. Products, Pricing and Price Books

- Product catalog.
- Price Book management.
- Price Book entries and pricing.
- Duplicate-entry protection through appropriate database constraints plus application handling.
- Commercial decimals must retain intended precision; money must not be silently converted to floating point.
- Price changes and important commercial mutations should be auditable.
- Quote calculations must use authoritative server-side pricing data.

SECURITY NOTE: A UI duplicate check is not a substitute for a database uniqueness invariant where the business rule requires one.

12. Quotes, Versions and Approvals

- Quote creation from valid Customer/Deal relationships.
- Quote versioning.
- Pricing and discount rules.
- Approval workflow.
- Approval authorization and self-approval prevention where policy requires.
- Quote state persistence across navigation/refresh.
- Audit trail for approval-sensitive actions.
- Transactional consistency when quote state, audit, workflow and outbox records change together.
- No customer/deal mismatch may be accepted merely because IDs are syntactically valid.

13. Tasks, Activities and Timeline

- Create and assign tasks.
- Due dates and completion state.
- Activity/timeline history.
- Authorized updates.
- Tenant and role scope.
- Safe date validation and serialization.
- Notification/workflow integration where configured.

14. Search, Reporting and Exports

- Global/domain search where implemented.
- Search results must respect tenant and permissions.
- Empty/error/loading states must be truthful.
- Date filters are server-enforced.
- Exports are bounded and authorized.
- Large exports must not become uncontrolled memory/CPU workloads.
- Export/download URLs require authorization at access time.
- Sensitive fields should be minimized in exports.
- Reports must not leak aggregate information across tenants.

15. Internal Communication

Internal communication is for employees/Admins inside the same company deployment. It must be integrated with the CRM identity rather than becoming a second user directory.

- Internal chat.
- Internal mail/message capability where implemented.
- Conversation participants are validated against the authenticated user's tenant and permissions.
- Message access is authorized server-side.
- Realtime delivery is separate from persistence authorization.
- Realtime channel names/IDs are not security boundaries by themselves.
- Presence/typing are treated as realtime state, not authorization proof.
- Rate limiting and abuse controls apply.
- Cross-tenant participant injection must be denied.
- Messages/attachments require authorization at read/download time.

16. Internal Calling — Why Twilio Is NOT the Core Calling Mechanism

The final product's internal calling is intended to be browser-to-browser/in-app calling between authenticated CRM users, not PSTN telephone calling. Therefore Twilio telephony is not the core mechanism for this internal feature.

The user experience should resemble the account-based calling experience people recognize from modern collaboration/social products:

```
Employee A logs into CRM
↓
CRM identity/session proves who A is
↓
A sees authorized colleagues
↓
A selects Employee B
↓
Server authorizes the call relationship
↓
CallSession created
↓
Realtime signaling exchanges offer/answer/ICE information
↓
WebRTC establishes browser media path
↓
Audio/video flows peer-to-peer when network conditions permit
↓
CRM records call state/log according to policy
```

This means the CRM user's username/email/account identity is the identity used to find and call another CRM user. The caller does not need a separate Twilio phone number merely to call another CRM employee.

- CRM authentication determines caller identity.
- Server authorization determines whether caller may initiate a call to the target.
- CallSession stores application call state.
- A managed realtime service such as the project's Pusher-based signaling architecture can relay signaling messages.
- WebRTC handles browser media negotiation and media transport.
- STUN helps discover network paths; TURN may be required for networks where direct peer connectivity fails.
- Actual media connectivity is a separate certification dimension from signaling.
- The system must never claim a successful call solely because a CallSession was created.
- Call logs must not be treated as proof that audio/video actually flowed.
- Microphone/camera permission is controlled by the browser and must be reflected truthfully in UI.

SECURITY NOTE: Current project records explicitly separate CallSession state, realtime signaling, RTCPeerConnection state and actual media connectivity. Full WebRTC E2E certification requires real realtime infrastructure and dual-browser/media testing.

17. Internal Calling Security

- Only authenticated CRM users can initiate/accept calls.
- Caller and callee must belong to the authorized tenant/deployment.
- Target user IDs are server-validated.
- Call channel authorization is server-side.
- Signaling messages must be authorized to the CallSession/channel.
- Random channel names are not authorization.
- Expired/ended calls reject late signaling.
- Replay/stale signaling must be handled safely.
- CallSession transitions must be validated server-side.

- One-active-call race protection must be tested where required.
- Cross-tenant signaling attempts must be denied.
- Call media must not be exposed through a public unauthenticated endpoint.
- Call logs must not expose private participant data unnecessarily.
- Browser permissions and connection state must be truthful.
- TURN credentials, if used, must be short-lived/appropriately scoped rather than permanent secrets embedded in frontend code.

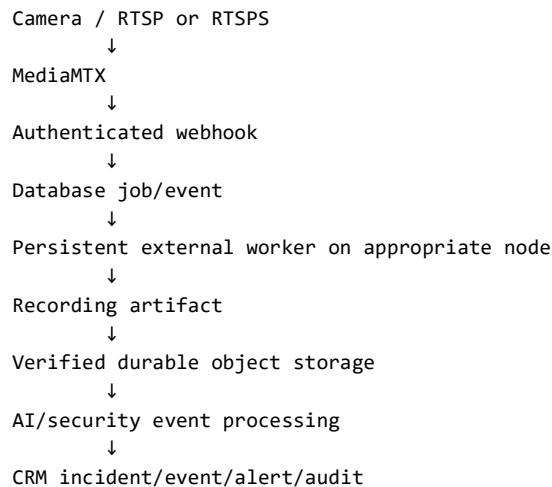
18. External Email, SMS, Telephony and WhatsApp

These are provider-dependent capabilities. They should exist in the product UI and architecture, but missing provider credentials must produce an explicit unavailable/degraded state rather than fake success.

Capability	Core product role	Typical provider direction	Missing credential behavior
Email	Customer/employee email workflows	Resend adapter or supported provider	Unavailable/degraded; never fake sent/delivered
SMS	External/customer messaging where enabled	Twilio adapter or supported provider	Unavailable/degraded; no unintended send
PSTN Telephony	Actual phone-number calling if purchased/enabled	Twilio or another supported telephony provider	Unavailable/degraded
WhatsApp	External WhatsApp messaging	Meta/WhatsApp integration	Unavailable/degraded
Internal calling	CRM user-to-user browser call	WebRTC + realtime signaling; NOT Twilio telephony	Calling not E2E-certified until infrastructure is available

19. CCTV / Security Operations

CCTV is a security-operations subsystem and must not be implemented as a persistent worker inside serverless routes.



- Camera source configuration is tenant/deployment scoped.
- Camera credentials are secrets and never exposed to ordinary employees.
- RTSP/RTSPS URLs must be validated and protected against SSRF/path abuse.
- MediaMTX API/webhook interfaces require authentication/signature controls.
- Recording workers run persistently outside Vercel serverless routes.
- Worker leases and fencing prevent stale workers from writing after lease loss.
- Node affinity is used where local recording files exist.
- Local recordings are not deleted until durable storage/integrity and DB confirmation meet policy.
- Object storage uses signed/authorized access.
- Playback/download authorization is checked at access time.
- Webhook requests require authentication, replay protection and idempotency.
- Retention/deletion policies are explicit.

20. AI Assistant and Security Intelligence

AI is an assistant operating inside the CRM security boundary, not an administrator with unrestricted database access.

- AI provider abstraction allows a supported provider to be configured without rewriting CRM business logic.
- Application-side authorization runs before privileged AI tools execute.
- AI receives only the tenant/user context and data necessary for the task.
- Tool registry controls which operations AI may invoke.
- High-impact/approval-sensitive operations require explicit authorization and may require human confirmation.
- AI actions/tool calls are audited without unnecessary prompt/PII logging.
- Prompt injection must not change the authorization boundary.
- AI cannot invent a permission because a prompt asks for it.
- AI cannot bypass RLS or use unrestricted database credentials.
- Provider timeout/retry/error/degradation behavior is explicit.
- Missing AI credentials must show degraded/config-required state, never fabricated inference.
- CCTV AI is enabled only after the underlying camera/recording/storage pipeline is proven.
- Cost precision and provider usage must be protected from manipulation.

21. Notifications and Workflows

- Notifications are tenant/user scoped.
- Unread/read state is persisted appropriately.
- Notification preferences are enforced.
- Outbox processing is authenticated and idempotent.
- Retries use safe backoff.
- Duplicate events are suppressed where required.
- Dead-letter/recovery behavior is observable.
- Worker leases/fencing protect against stale concurrent workers.
- A notification must never reveal data the recipient could not otherwise access.

22. UI/UX — Global Experience

The final UI should feel like one coherent business application rather than a collection of disconnected modules.

- Clear left/sidebar navigation grouped by business domain.
- Dashboard with role-appropriate cards, trends, recent activity and alerts.
- Global search with permission-scoped results.
- Quick Add for common CRM actions.
- Consistent detail pages with tabs/sections.
- Consistent modal/drawer patterns.
- Inline editing only where safe and obvious.
- Loading states that prevent duplicate submissions.
- Disabled states that explain unavailable prerequisites.
- Empty states with useful next actions.
- Error states that are actionable but do not expose internal stack/database details.
- Toast/inline success and error feedback.
- Confirmation for destructive/high-impact actions.
- Keyboard-friendly controls and accessible focus behavior.
- Responsive layouts for common desktop/tablet/mobile use cases as supported.
- No layout hydration-dependent content that causes unstable UI.
- Timestamps use an explicit timezone policy.
- Search/filter state survives reasonable navigation where appropriate.
- No fake success indicators when an external provider is unavailable.

23. UI/UX — Admin Experience

- Company dashboard.
- Customer/Contact management.
- Lead and pipeline views.
- Deal management.
- Product/Price Book.
- Quotes and approvals.
- Tasks/Activities.
- Tickets/incidents if enabled.
- Reports/analytics.
- Employee/workforce management.
- Communication.
- Calling.
- CCTV/security operations where enabled.
- AI assistant.
- Notifications.
- Security/settings.
- Profile/session management.

Admin UI must reflect actual permissions; however, hiding a button is never considered an authorization control.

24. UI/UX — Employee Experience

- Employee dashboard tailored to permitted work.
- Assigned customers/leads/deals/tasks.
- Permitted communication.
- Internal calling/presence where enabled.
- Notifications.
- Role-appropriate reports.
- AI assistant within the same authorization boundary.
- Profile/security settings permitted to the Employee.
- No Admin navigation merely because the user can guess a URL.
- Direct server denial for forbidden actions.

25. Security Architecture — Defense in Depth

Layer 1 Authentication
Layer 2 Session security
Layer 3 Server-side authorization
Layer 4 Tenant context
Layer 5 Input/schema validation
Layer 6 Database constraints
Layer 7 PostgreSQL RLS/FORCE RLS
Layer 8 Audit/security events
Layer 9 Rate limiting / abuse controls
Layer 10 Provider/webhook authentication
Layer 11 Observability / alerting
Layer 12 Recovery / DR

No single layer is permitted to carry the entire security model.

26. Security Checks AI Tools Commonly Forget

- Server-side authorization even when the frontend hides a control.
- Tenant validation on every object relationship, not only top-level pages.
- Cross-tenant IDOR tests using valid-looking foreign IDs.
- Mass-assignment attempts for tenantId, roleId, userId, status and permissions.
- RLS/FORCE RLS verification, including interactive transaction behavior.
- Database uniqueness constraints for security/business invariants.
- Session fixation testing.
- Stale-session behavior after user disablement.
- Logout token reuse testing.
- Global logout testing.
- Concurrent invitation redemption.
- Concurrent password-reset token redemption.
- Recovery-code replay.
- MFA removal/re-enrollment security.
- Account enumeration through login/reset/verification.
- Timing differences in authentication failures.
- Distributed brute-force/credential-stuffing behavior.
- Rate-limit failure semantics.
- Redis outage behavior without security bypass.
- CSRF on cookie-authenticated mutations.
- Origin/Referer checks where appropriate.
- Webhook signature verification.
- Webhook replay protection.
- Webhook idempotency.
- Stale worker fencing.
- Node affinity for persistent files.
- Deleting CCTV files before durable-storage confirmation.
- Signed URL authorization at access time.
- SSRF against camera/MediaMTX URLs.
- Path traversal/symlink attacks against recording paths.
- Realtime channel authorization rather than channel secrecy.
- Late/replayed WebRTC signaling.
- AI prompt injection preserving authorization boundaries.
- AI tool authorization independent of prompt instructions.
- No unrestricted AI DB credentials.
- Provider-missing behavior without fake success.
- No secret exposure in browser bundles.
- No secret exposure in logs/error trackers.
- No production credentials in local/E2E.
- No temporary credential dump files.
- No hardcoded test/admin bypass in production.
- No unsafe fallback authentication mechanism.
- No security state depending solely on eventually consistent UI/cache.
- No destructive production testing without explicit authorization.
- No PASS based only on source inspection when runtime evidence is required.
- No production certification based on historical/local tests alone.

27. Data Protection Rules

- Sensitive credentials are stored only in approved secret/key-management systems.
- Passwords are stored only as password hashes.

- Session tokens are stored only as hashes.
- Reset/invitation/verification tokens are stored only as hashes.
- MFA secrets are protected using an explicit secret/encryption strategy.
- Secrets never appear in logs, screenshots, reports or source control.
- Sensitive API responses are minimized.
- Downloads/attachments require authorization at time of access.
- Audit logs avoid unnecessary PII.
- Retention and deletion are documented for business and security data.

28. Workers, Queues and Background Processing

- Workers claim jobs with leases.
- Lease ownership is fenced so stale workers cannot write after losing ownership.
- Retries are idempotent.
- Duplicate delivery is expected and safely handled.
- Workers preserve tenant context.
- Background jobs never trust arbitrary tenant/user IDs without validation.
- Long-running processing is outside short-lived serverless routes when persistence is required.
- Worker shutdown/recovery is observable.

29. Observability and Audit

- Live/ready/health endpoints have clear meanings.
- Provider health states distinguish READY, MISSING_CREDENTIALS, MISCONFIGURED and UNAVAILABLE where applicable.
- Security events are auditable.
- Authentication events are auditable.
- Provider failures are observable without secret disclosure.
- Worker latency/failure/retry metrics are visible.
- Realtime/calling state can be investigated without treating it as media proof.
- CCTV job and storage transitions are traceable.
- AI tool actions are auditable.
- Correlation IDs connect request/job/provider events where appropriate.

30. Disaster Recovery and Production Operations

- Backups have documented frequency and retention.
- Restore drills are performed in an isolated environment.
- Measured RPO/RTO are documented rather than assumed.
- Recovery restores security controls, not only data.
- Tenant isolation is retested after restore.
- Credential rotation runbooks exist.
- Provider outage runbooks exist.
- Database recovery runbooks exist.
- Worker/CCTV node failure runbooks exist.
- Security incident response includes session revocation and credential rotation.

31. Scale and Performance

- Define expected concurrency per isolated company.
- Load-test authentication/session validation.

- Load-test CRM transactions and reporting.
- Load-test communication/outbox.
- Load-test calling signaling/CallSession where infrastructure exists.
- Load-test CCTV ingestion/workers separately.
- Measure DB connection/pooling behavior.
- Measure p50/p95/p99 latency and error rates.
- Repeat security tests after performance optimizations.

32. Final Client Credential / API Manifest

The following is the final target intake list. Not every client must provide every item. Credentials are requested only when the corresponding capability is being activated and the provider is supported by an existing adapter or a separately validated new adapter.

Category	Client may need to provide	Why	How to obtain / configure	Handling
Company identity	Legal/company name, deployment identifier, primary admin contact, preferred domain/subdomain	Create isolated customer deployment and bootstrap Admin	Provided by client's authorized operator/business owner	Non-secret metadata
Database	PostgreSQL/Supabase project or approved compatible PostgreSQL credentials	CRM persistence	Client creates dedicated project/database; provide connection details through secure secret store	SECRET; never chat
Native authentication	Normally no third-party auth API key	CRM owns authentication	Provisioned as part of CRM deployment; admin users are created through controlled onboarding	Passwords/secrets never shared with us in chat
Encryption/key management	Client-managed key if contract/deployment model requires it	Protect sensitive authentication/provider data	Generated/provisioned through approved secret/key store	HIGHLY SENSITIVE
Redis	Redis/Upstash endpoint and credential if required by deployment	Rate limits, cache, session acceleration, jobs as designed	Create isolated Redis DB; secure secret-store injection	SECRET
Email	Resend API key or another supported email provider credential	Verification, reset, invitations, external email	Create provider account/domain; generate API key; configure sender/domain	SECRET
SMS/PSTN	Twilio Test/Production credentials or supported telephony provider credentials	External SMS/phone-number telephony only	Client creates provider account and API credentials	SECRET
WhatsApp	Meta app credentials, phone-number/business identifiers, webhook secret/token as required	WhatsApp integration	Create/configure Meta business/app assets and secure webhook	SECRET
AI	Gemini or another supported AI provider API key	AI assistant/security intelligence	Client creates provider project/API key with appropriate restrictions	SECRET; never frontend
Object storage	S3-compatible bucket/endpoint/access credentials	CCTV recordings, files and durable objects	Create isolated bucket + least-privilege service credential	SECRET
CCTV	Camera RTSP/RTSPS endpoints, camera credentials, approved network details	Camera ingestion	Client/security operator provides approved camera configuration through secure channel	SECRET / sensitive
MediaMTX	API/JWT/webhook secrets and deployment endpoint where applicable	CCTV streaming/recording control	Provision isolated MediaMTX and generate secrets	SECRET
Realtime signaling	Pusher credentials if the client owns the realtime provider	Chat/presence/WebRTC signaling	Create isolated provider app/cluster and server/client keys	SECRET; client key only if intentionally public
Jobs	Inngest/worker credentials if selected for the deployment	Background processing	Provision isolated job/worker account	SECRET
TURN	TURN service credentials only if the selected WebRTC deployment requires external TURN	NAT traversal for browser calls	Provision approved TURN service/server; use short-lived credentials where possible	SECRET; never hardcode permanent browser secret
DNS/domain	Domain/DNS access or delegated records	Custom deployment domain, email verification,	Client creates/delegates required DNS records	Access controlled

		provider callbacks		
Provider webhooks	Webhook signing secret/configuration	Authenticated inbound events	Generate provider webhook secret; configure exact callback URL	SECRET

SECURITY NOTE: This list is an intake manifest, not permission to request every secret immediately. The project rule is to request credentials only after the core product/security gates are satisfied and only for a capability whose prerequisites genuinely require them.

33. What We Should NOT Ask a Client to Send in Chat

- Database passwords or full DATABASE_URL strings.
- Authentication encryption keys.
- API keys.
- OAuth client secrets.
- Webhook signing secrets.
- SMTP/API passwords.
- Twilio auth tokens.
- Meta app secrets.
- AI API keys.
- Storage access keys/secret keys.
- Camera passwords.
- MediaMTX secrets.
- Realtime provider server secrets.
- TURN long-lived credentials.
- Employee passwords.
- Admin passwords.
- Session cookies.
- MFA recovery codes.
- Password reset tokens.

These must be supplied through the approved secret/deployment configuration process. The operator should record only metadata such as CONFIGURED, NOT CONFIGURED, MISCONFIGURED, UNAVAILABLE or DEFERRED.

34. How Client Provisioning Works

1. Confirm the client's company identity and authorized technical contact.
2. Create the isolated customer deployment/environment.
3. Provision or connect the client's isolated database.
4. Provision native authentication and bootstrap the first authorized Admin through the controlled setup process.
5. Provision Redis if required.
6. Configure encryption/security secrets.
7. Configure only the providers the client actually purchased/selected.
8. Inject secrets through the deployment secret store.
9. Verify configuration without printing secret values.
10. Run health/readiness checks.
11. Run Admin authentication and core CRM tests.
12. Create/invite Employee through the intended lifecycle.
13. Run Employee authorization/security tests.
14. Activate optional providers one at a time.
15. Run real E2E verification for each activated provider.
16. Run security/tenant-boundary regression tests.
17. Record evidence and known limitations.
18. Freeze the certified deployment configuration.

35. Provider Portability Rules

State	Meaning	Allowed behavior
SUPPORTED NOW	Existing adapter and verified runtime support	Configure and certify
SUPPORTED THROUGH EXISTING INTERFACE	Compatible implementation exists	Configure after compatibility verification
NO ADAPTER	Credentials alone are insufficient	Build + test adapter before claiming support
UNSUPPORTED	Infrastructure/provider mismatch	Do not claim support merely because credentials exist

Examples such as another PostgreSQL host, another email provider, another realtime provider or another hosting platform must be treated as compatibility questions. Credentials do not magically make unsupported infrastructure compatible.

36. Provider Degradation Rules

- Missing optional email: email UI remains truthful; no fake sent/delivered state.
- Missing SMS/telephony: no unintended send/call; capability state is explicit.
- Missing realtime: chat/calling state degrades according to the implemented fallback; no fake realtime success.
- Missing WebRTC infrastructure: calling may exist as UI/application architecture but is not E2E-certified.
- Missing AI: show disabled/degraded/config-required state; never fabricate inference.
- Missing CCTV: no fake stream/recording/token.
- Storage failure: never claim durable upload or recording.
- Worker failure: retry/defer safely; never claim completion without evidence.
- Redis failure: never bypass a security-critical control merely to keep the feature working.

37. Certification Gates for the Final Product

Gate	Required evidence
Company isolation	Actual isolated deployment/infrastructure/credential boundary
Authentication	Native Admin + Employee login/session/revocation evidence
Admin	Complete Admin workflow runtime evidence
Employee	Complete Employee workflow + forbidden-action runtime evidence
Core CRM	Customer/Contact/Lead/Deal/Task lifecycle evidence
Revenue	Products/Price Book/Quotes/Approvals evidence
RBAC	Server-side authorization tests
Tenant isolation	Cross-tenant adversarial evidence
IDOR	Object substitution tests
Mass assignment	Payload mutation tests
Internal communication	Persistence + authorization + realtime evidence as applicable
Internal calling	CallSession + signaling + browser media separately evidenced
CCTV	Camera → MediaMTX → worker → storage → event chain evidence
AI	Real provider + authorized tools + audit evidence
Providers	Actual provider state, not assumptions
Observability	Health/metrics/log evidence
DR	Restore drill + measured RPO/RTO
Scale	Real concurrency/load evidence
Secrets	No exposure + correct secret-store isolation
Production	Deployment-specific final certification

38. Final Release Rules

- Show the working product.
- Prove security and architecture.
- Confirm required integrations.
- Request only necessary credentials.
- Activate one provider at a time.

- E2E verify each activated provider.
- Document known limitations.
- Never call implementation maturity the same thing as production certification.
- Never use customer credentials to hide unfinished core product behavior.
- Never weaken security to make a demo pass.

39. Final Product Security Invariants

INVARIANT 1

A user cannot authenticate as another user.

INVARIANT 2

A user cannot choose their tenant.

INVARIANT 3

A user cannot choose their role or permissions through a request payload.

INVARIANT 4

An Employee cannot become Admin through UI manipulation, API calls, IDOR, mass assignment or stale session state.

INVARIANT 5

A disabled user cannot continue using an old session.

INVARIANT 6

Logout invalidates the server-side session.

INVARIANT 7

A reset/invitation/verification token cannot be replayed.

INVARIANT 8

Cross-tenant records cannot be accessed even when a valid-looking ID is supplied.

INVARIANT 9

RLS/FORCE RLS remains a database backstop.

INVARIANT 10

AI cannot bypass application authorization.

INVARIANT 11

Realtime channel possession does not equal authorization.

INVARIANT 12

CCTV media/object access is authorized independently of UI visibility.

INVARIANT 13

Provider failure never becomes fabricated success.

INVARIANT 14

Secrets never appear in source, logs, browser bundles or chat.

INVARIANT 15

Persistent workers never rely on serverless process lifetime.

INVARIANT 16

A worker that loses its lease cannot perform stale writes.

INVARIANT 17

No security PASS is declared without the required evidence.

40. What the Finished CRM Should Feel Like

To the client, the finished product should feel like a single coherent company operating system for customer relationships, revenue, workforce collaboration and security—not a collection of provider dashboards.

- Admin signs in and immediately sees the company's operational picture.
- Admin can manage customers, pipeline, revenue, workforce and security from one product.
- Admin can invite an Employee without manually creating a parallel account in a third-party identity platform.
- Employee signs in with their own company account and sees only the work they are authorized to see.
- Employees can collaborate internally through chat and browser calling without needing external phone numbers for internal calls.
- External communication activates only when the company configures the corresponding provider.
- CCTV becomes a secure operational workspace rather than an unaudited video viewer.
- AI helps with authorized CRM/security work rather than becoming an unrestricted database operator.
- Every provider-dependent capability clearly communicates its real state.
- Security is enforced invisibly at every layer rather than being a collection of visible warnings.

41. Final Architectural Principle

ONE PRODUCT EXPERIENCE — SEPARATE COMPANY ENVIRONMENTS — OWNED COMPANY IDENTITIES — SERVER-SIDE AUTHORIZATION — DATABASE-ENFORCED TENANT BOUNDARIES — PROVIDER-ISOLATED INTEGRATIONS — EVIDENCE-BACKED SECURITY.

The final CRM is not complete merely because all pages exist. It is complete when the company, Admin and Employee experiences work together; security boundaries survive direct API attempts and hostile inputs; provider failures are truthful; recovery and operations are tested; and each customer can be provisioned as an isolated, repeatable deployment.

42. Current vs Final Target — Important Boundary

Area	Final target	Current project reality
Authentication	CRM-native authentication	Migration/design phase; current runtime still has legacy Clerk dependencies
Company isolation	Separate deployment/environment/infrastructure/credentials per company	Architectural direction established; each new customer deployment requires provisioning evidence
Admin workflow	Complete runtime-verified workflow	Substantial hosted verification already exists; final certification broader
Employee workflow	Complete runtime-verified workflow	Runtime verification has been blocked by the current authenticated test environment
Internal calling	WebRTC + realtime signaling, no Twilio for internal calls	CallSession/signaling foundation exists; full browser-media E2E requires real infrastructure
CCTV	MediaMTX + persistent worker + storage	Architecture established; real infrastructure E2E remains a certification gate
AI	Controlled authorized tools + real provider evidence	Provider/tool foundation exists; final provider certification remains
DR/Scale	Restore drills + measured RPO/RTO + real load evidence	Not fully certified
Production	Deployment-specific final certification	Not complete

43. Source Basis

This document is grounded in the project's supplied architecture, roadmap, testing, credential-handling, progress and authentication materials. Key source documents used include:

- Goal.docx and the project architecture/goal materials.
- fresh Roadmap.docx.

- Updates From fresh roadmap till now and Future Plan.docx.
- Testing Conditions.docx.
- Achieve this first, Rest later.docx.
- How to handle credentials.docx.
- Before asking for credentials.docx.
- Recent Updated - 02 Date _ 16th September 2026.docx.
- Project Progress Summary and historical progress records.
- New Authentication System.docx.
- Current Employee workflow/authentication source audits and handovers.

SOURCE / DESIGN BOUNDARY: Where the source material describes the existing implementation, this document preserves that distinction. Where it describes the final target architecture, the text is presented as a target rather than proof that the capability is already certified.

44. Final Goal Statement

A secure, isolated, repeatably deployable CRM for each company, with company-owned authentication, Admin and Employee workflows, complete CRM/revenue operations, internal communication and browser calling, CCTV/security operations, controlled AI, truthful provider integrations, strong tenant/RBAC/RLS boundaries, auditable operations, recoverability, and evidence-backed production certification.